SANDIP UNIVERSITY
UGC Recognised

NAAC GRADE A

PROJECT REPORT

STRIDE Threat Model Study: Mapped Microservice Data Flows and Structural Threats Using OWASP Threat Dragon

Domain: Application Security **Approach:** STRIDE threat modeling **Tool:** OWASP Threat Dragon

Abstract

This project documents a repeatable approach to identifying structural security threats in a microservice architecture using STRIDE and OWASP Threat Dragon. It focuses on mapping components, data flows, trust boundaries, and representative threats involving identity, integrity, accountability, confidentiality, availability, and authorization. A Python helper generates a CSV threat register with illustrative scenarios, risk scores, recommended mitigations, owners, and status. The register complements—not replaces—a visual model and stakeholder review.

1. Introduction

Microservice architectures distribute application responsibilities across services, APIs, message brokers, data stores, and identity systems. This can improve scalability and deployment independence, but it also creates additional trust boundaries and service-to-service paths. Threat modeling helps teams identify where security properties may fail before incidents occur. STRIDE provides a structured set of threat categories that can be applied to system components and data flows.

2. Objectives

• Describe a practical threat-modeling workflow for a microservice application.

• Map example service-to-service data flows and trust transitions.

• Classify representative threats using Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.

• Generate a structured threat register with prioritization and treatment tracking.

• Use OWASP Threat Dragon to visualize architecture and support collaborative review.

3. STRIDE Methodology

Category	Threat concept	Example in a microservice system
Spoofing	Impersonation	A caller presents a stolen token or an unauthorized workload impersonates a service.
Tampering	Unauthorized modification	A payment amount or message payload is changed.
Repudiation	Insufficient evidence to attribute actions	A privileged state change cannot be tied to an actor or service.
Information Disclosure	Unauthorized data exposure	An API returns another customer's profile.
Denial of Service	Loss of availability	Expensive queries or poison messages exhaust resources.
Elevation of Privilege	Gaining unintended permissions	A worker account invokes administrative functions.

4. Architecture and Data-Flow Modeling

A useful model should include external actors, API gateways, identity providers, application services, message brokers, databases, secrets stores, observability systems, and administrative interfaces where applicable. Draw directed data-flow arrows and label protocols, authentication methods, and sensitive data. Mark trust boundaries wherever data crosses from a less trusted context to a more trusted one—for example, public ingress to an API gateway, one workload identity to another, or an application service to a database.

5. Tools and Implementation

OWASP Threat Dragon is used to create and review visual threat models. The included Python CLI is a companion utility that produces a CSV register of ten illustrative threats. Each entry includes the component or flow, data being transferred, STRIDE category, scenario, security property, assumed existing controls, recommended mitigations, likelihood, impact, score, rating, owner, and status. The Python script uses only the standard library.

6. Risk Scoring

The example score is likelihood × impact, with both inputs rated from 1 to 5. Example bands are 1–7 Low, 8–14 Moderate, 15–19 High, and 20–25 Critical. Organizations should use their approved risk matrix and document rating rationale. These scores support prioritization but are not precise probability estimates.

7. Example Threat Register Summary

ID	Component / flow	STRIDE	Score	Rating
STRIDE-001	API Gateway → Identity Service	Spoofing	15	High
STRIDE-002	Order Service → Payment Service	Tampering	15	High
STRIDE-003	Order Service → Audit Log	Repudiation	12	Moderate
STRIDE-004	Customer API → Customer Database	Information Disclosure	15	High
STRIDE-005	Public API → Search Service	Denial of Service	16	High
STRIDE-006	Worker → Admin API	Elevation of Privilege	15	High
STRIDE-007	Message Broker → Inventory Service	Tampering	12	Moderate
STRIDE-008	Microservice → Secrets Store	Information Disclosure	15	High
STRIDE-009	Service Mesh / Internal Network	Spoofing	12	Moderate
STRIDE-010	Event Consumer → Data Store	Denial of Service	12	Moderate

8. Workflow Using OWASP Threat Dragon

1. Define the application scope and security objectives.
2. Create a diagram with processes, data stores, external entities, data flows, and trust boundaries.
3. Annotate sensitive data and the authentication/authorization used on each flow.
4. Brainstorm threats using all six STRIDE categories, especially at trust boundaries.
5. Record mitigations, accountable owners, evidence, and residual concerns.
6. Review the model with developers, platform engineers, operations, and security teams.
7. Track mitigation completion and revisit the model after architecture changes.

9. Limitations and Recommendations

• The sample architecture and controls are illustrative assumptions, not verified facts about a deployed system.

• Threat-model quality depends on diagram completeness and correct identification of trust boundaries.

• Validate mitigations against actual technology, business requirements, and threat intelligence.

• Do not publish confidential service names, topology, secrets, or exploitable details in a public repository.

• Re-run threat modeling when new services, data stores, trust relationships, or external integrations are introduced.

10. Conclusion

STRIDE threat modeling gives teams a systematic way to explore security failure modes in microservice data flows. OWASP Threat Dragon supports visual modeling, while the Python helper supports structured tracking and risk prioritization. Together, they can improve communication and remediation planning when the model is based on accurate architecture, reviewed by stakeholders, and maintained over time.

References

• OWASP Threat Dragon: https://owasp.org/www-project-threat-dragon/ • OWASP Threat Modeling: https://owasp.org/www-community/Threat_Modeling

Prepared as an educational project report. The example threat register is not a security certification or proof of system security.